

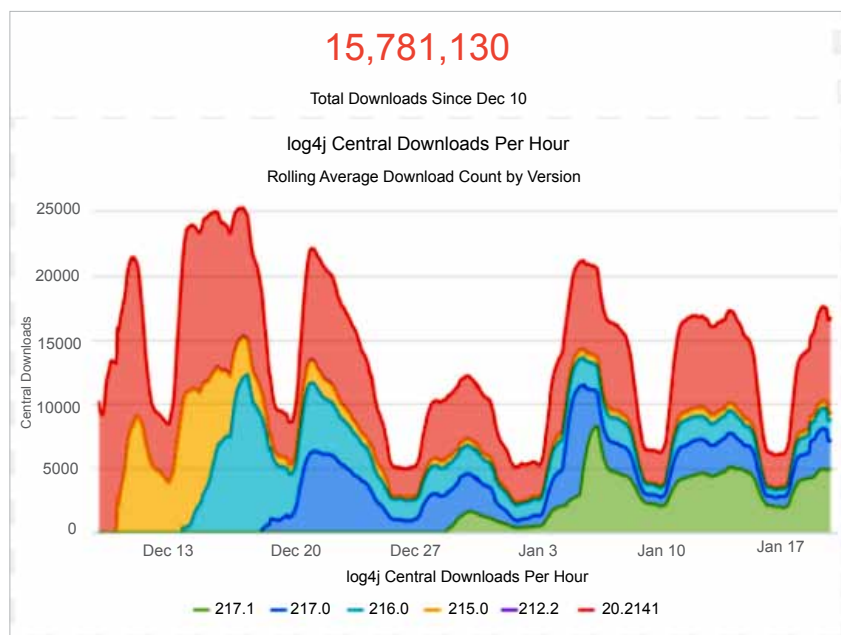


Figure 1: Log4j download

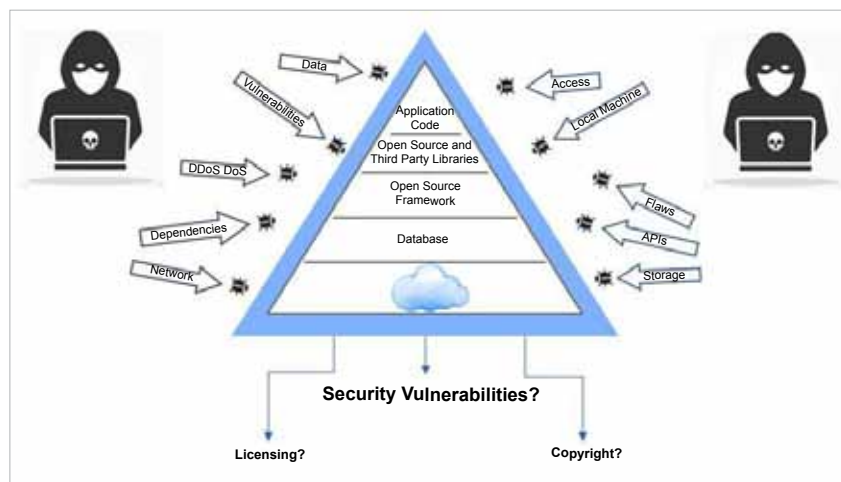


Figure 2: Modern software solutions

Iran and North Korea have started testing, exploiting and using the Log4j bug to deploy a variety of malware, including ransomware.

Log4Shell: A vulnerability or a 'cluster-bomb of zero-days'?

The Log4Shell vulnerability has been described as a 'cluster-bomb of zero-days' because it is such a foundational component in so many software frameworks that are available to developers for reuse.

Many pieces of software have logging libraries. It is highly unlikely that organisations, especially big corporations, are coding their own logging software. There is no benefit to this when an open source version is easily available. Log4j is widely used for this reason and, consequently, Log4Shell has impacted a very wide range of software and services from many major vendors.

Dependencies play a large role in the wide stretch of the Log4j

vulnerability. According to one commentator: "It is mind-boggling how big dependency trees can get." This is why so many users had no idea they were running affected Log4j versions between the thousands of dependencies in their stack.

As the number of Log4j exploits grew rapidly towards the end of last year, warnings were issued by several national cyber security agencies, including the US's Cybersecurity and Infrastructure Security Agency (CISA) and the UK's National Cyber Security Centre (NCSC).

The US's Federal Trade Commission (FTC) has said that it "intends to use its full legal authority to pursue companies that fail to take reasonable steps to protect consumer data from exposure as a result of Log4j."

The severity of the Log4j vulnerability has served as a wake-up call to organisations. It demonstrates you must understand what is in your software, where dependencies lie and not leverage vulnerable components, especially when safe ones are available.

Sonatype, a software company and core contributor of Apache Maven, reported that since December 10, 2021, when Log4Shell was disclosed, Log4j has been downloaded more than 10 million times (see Figure 1). It stated that nearly half of these were unsafe versions, despite the fact that fully patched and secure versions were available at the time.

Ilkka Turunen, field CTO at Sonatype, says, "The fact that we are still facing such high percentages of vulnerable downloads is indicative of a much bigger problem with supply chain security... If companies don't understand what's in their software, they're unable to act with the requisite speed when threats arise - and in this instance, given the huge popularity of Log4j, this exposes them to significant risk."

The reality is that if a vulnerable software project like Log4j has been sitting in the heart of the world's